

Modul 13 Leverandørstyring

Forretningsforståelse



Agenda

1. MC opsamling på sidste lektion
2. Status på moduler
3. Supply Chain Management
4. Modeller til vurdering/øvelser
5. Anvendelse af SCM på Hvedebro

Supply chain angreb – op mod 2000 virksomheder ramt i hver af de 2 angreb

Solarwinds: Fejl med kodeord 'solarwinds123' var praktikantens skyld

Cyberkriminalitet 1. marts 2021 kl. 10:42 37 kommentarer



Supply chain-angreb rammer tusindvis med ransomware

Ransomware 4. juli 2021 kl. 08:46 13 kommentarer



Illustration: Coop.

Blandt ofrene for angreb via Kaseya VSA-software er svenske Coop, der måtte lukke butikkerne lørdag.

Supply Chain Management

- Hvad er supply chain i en digital kontekst?
 - Leverandører af hardware, software og cloud
 - Outsourcing- og serviceleverandører
 - 3.- og 4.-parts forhold/risiko
 - Afhængighed på tværs af teknologier og geografier
- Hvorfor er leverandørkæder blevet mere sårbare?
 - Leverandører kan være svageste led
 - Antal årlige supply chain attacks forventes ifølge ENISA at stige fremover*
 - Komplexitet skaber nye angrebsvektorer
 - Regulering (NIS2, DORA) stiller nye krav til området

*ENISA - 2024 REPORT ON THE STATE OF CYBERSECURITY IN THE UNION



Hvorfor er leverandørstyring vigtigt?

1. Leverandører kan være det svageste led

Et kendt eksempel: *SolarWinds-angrebet*, hvor hackere kompromitterede en softwareleverandør og derigennem fik adgang til tusindvis af organisationer.

2. Software og opdateringer kan bruges som angrebsvektor

Dette kaldes "*software supply chain attacks*".

3. Fysiske komponenter kan manipuleres

Skjulte chips, manipuleret firmware, bagdøre

4. Outsourcing skaber flere angrebspunkter

Mange virksomheder outsourcer: drift, cloud, support

5. Regulering/standarder på området

NIS2, DORA, ISO 27036 (onboarding, kontrakter, kontrol, off-boarding), NIST 800-161



Opgave 1 CASE SolarWinds (G1+2), Kaseya (G3+4), NotPetya (G5/6), MOVEit (G7/8).

Hvad skete der i forbindelse med ovenstående incidents.

Beskriv:

1. Hvad blev de ramt af (hvad gik galt)?
2. Hvilke sikkerhedsbegreber er i spil – herunder CIA?
3. Hvad var konsekvensen?
4. Kunne kontroller have forhindret angrebet?
5. Hvad burde de forbedre?
6. Andre sikkerhedsovervejelser?

Brug nettet og lav et par beskrivende slides.

15 minutter til forberedelse. Vi hører 4 grupper – 5 min. til hver.

Typiske leverancekategorier til en virksomhed.

Kat	Produkt/ydelse	Eksempler	Eksempler på krav/overvejelser
1	Simple ydelser/produkter	• Levering af kontorartikler • Transport service	Ingen specielle udover basale krav til alle leverandører
2	Services	• Entreprenører, fx grave • Marketing • Ordrehåndtering	Eksporteres data, eller har leverandør adgang til interne IT-systemer? – Sikkerhedsstandarder, audit, rapportering
3	Tekniske produkter	• IT-applikationer • Netværksudstyr	Specifikke krav, udviklingsproces, penetration test, aftale om håndtering af sårbarheder og patches, sikkerhedsstandarder
4	Cloud services	• AWS, Azure mv. • Office 365	Specifikke sikkerhedsstandarder med tilhørende SOA Håndtering ved aftaleophør
5	Outsourcing	• Driftsaftaler	Specifikke krav, audit krav, BCM-integration, ISO-certificering og SOA, rapportering og governance aftale, håndtering ved aftaleophør

Leverandørkrav og dokumentation

- Risici i leverandørkæder **skal** være en del af virksomhedens egen risikoanalyse
- Hvad kan man så gøre i praksis?
 - Fokuser på hvad der er **kritisk og relevant mod den enkelte leverandør**
 - Tag en **dialog med leverandøren** - hvis muligt
 - Søg evidens (**beviser/dokumentation**) om nødvendigt
 - Kræv **løbende rapportering** på vigtige områder.

Opgave 2

2 og 2 opgave

- Hvilke leverandørkategorier/typer anvender Hvedebro i dag og evt. fremover jf. slide 6?
- Hvilke leverandører (områder) er **kritiske, vigtige** og **ikke-kritiske** for Hvedebro Maskinfabrik, at tage fat på ifm. sikkerhed?
- Prøv at lave en rangering af vigtighed.

Lav en tabel med ovenstående.

15 minutter til drøftelse 2 og 2 omkring bordet.

De to grupper ved bordet forklarer derefter deres respektive løsninger.

Hvorfor outsource? – jf. CFCS

Strategiske fordele

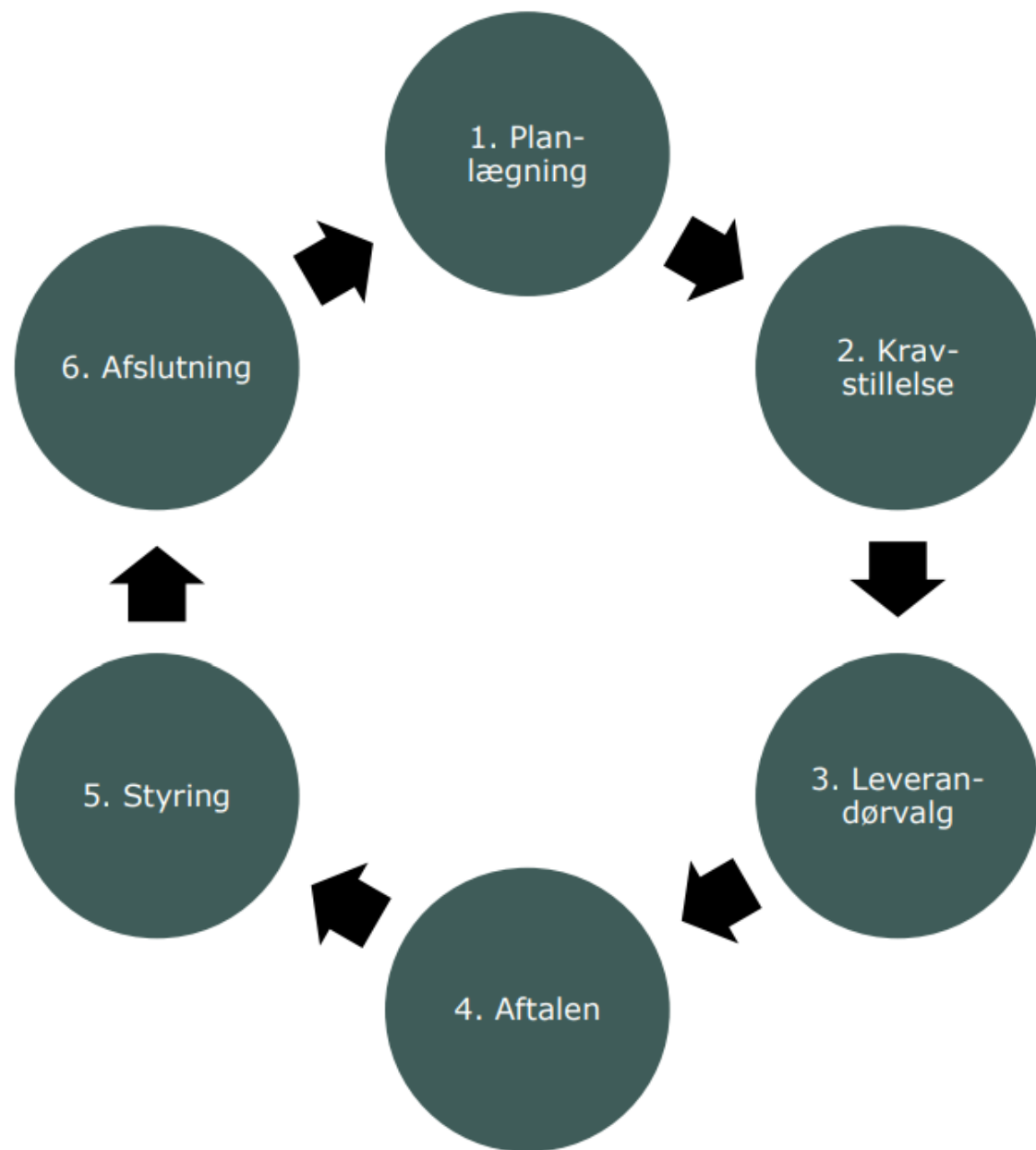
- Frigørelse af ressourcer til andre formål
- Prioritering af organisationens kerneforretning
- It-anskaffelser, som ikke kan udvikles internt til samme pris
- Effektivisering af it-driften
- Forbedre organisationens cyber- og informationssikkerhed

Operationelle fordele

- Mere stabil it-drift
- Adgang til leverandørens faglige ekspertise og erfaring
- Bedre vedligeholdelse, it-support og videreudvikling
- Øget brugervenlighed
- Adgang til ny og bedre teknologi
- Hjælp til dokumentation og rapportering



Indkøbsprocessen



1. Planlægning af udbud (sikkerhedskrav og sikkerhedsspecifikation)
2. Kravspecifikation udsendes incl. sikkerhedskrav
3. Budrunde (pris/løsning) – kan forekomme flere budrunder
4. Leverandørvalg
5. Styring/implementering (rapportering, audits mm.)
6. Afslutning (hvad skal der sikkerhedsmæssigt gøres ved terminering af aftalen)

Indhold af faser med henblik på sikkerhed (Outsourcing)

Fase	Anbefaling
1. Planlægning	1.1 Dokumentér interne og eksterne forhold vedrørende den planlagte outsourcing, der kan påvirke organisationens cyber- og informationssikkerhed.
	1.2 Kortlæg organisationens forretningsprocesser med fokus på den underliggende it-infrastruktur, herunder datastrømme og indbyrdes afhængigheder.
	1.3 Foretag en risikovurdering med fokus på særlige risici ved den planlagte outsourcing, der kan påvirke organisationens cyber- og informationssikkerhed.
	1.4 Formulér en separat politik for organisationens styring af cyber- og informationssikkerhed i kunde-leverandørforhold ved outsourcing af it.
	1.5 Etablér en intern organisation egnet til leverandørstyring med veldefinerede roller, de fornødne ressourcer og kompetencer, dokumenterede processer og den nødvendige it-understøttelse.
2. Kravstillelse	2.1 Stil relevante krav til leverandørens cyber- og informationssikkerhed på baggrund af en risikovurdering.
	2.2 Stil krav til leverandørens cyber- og informationssikkerhed med fokus på den ønskede effekt frem for den præcise løsning.
	2.3 Vurdér behovet for ekstern rådgivning og bistand, herunder inddragelse af CFCS, i forbindelse med udarbejdelsen af sikkerhedskrav til leverandøren.
3. Leverandørvalg	3.1 Vælg leverandør ud fra relevante kriterier og på baggrund af en grundig vurdering af leverandørens samlede evne til at opfylde sikkerhedskravene og de øvrige krav til opgaveløsningen.
4. Aftalen	4.1 Aftal en klar rolle- og ansvarsfordeling med leverandøren i forhold til parternes styring af cyber- og informationssikkerhed i kunde-leverandørforholdet.
	4.2 Etablér en samarbejdsorganisation og formaliseret proces for håndtering af dialogen med leverandøren, som både omfatter den daglige dialog og kommunikation i tilfælde af sikkerhedshændelser og i en beredskabssituation.
5. Styring	5.1 Dokumentér organisationens behov for at føre kontrol med leverandøren.
	5.2 Udpeg en dedikeret rolle med ansvar for organisationens leverandørstyring i forhold til opfyldelsen af sikkerhedskravene i kontrakten.
	5.3 Før løbende kontrol med leverandørens opfyldelse af sikkerhedskravene i kontrakten efter behov og på baggrund af en risikovurdering.
	5.4 Gennemfør løbende risikovurderinger med input fra leverandøren og eventuelle underleverandører.
	5.5 Håndtér evt. sikkerhedshændelser og væsentlige ændringer hos kunden, leverandøren eller i omgivelserne, der kan påvirke sikkerheden i leverancen.
6. Afslutning	6.1 Bevar cyber- og informationssikkerheden under afviklingen af kunde-leverandørforholdet.



Overordnede generelle leverandørspørgsmål

- Har virksomheden en sikkerhedspolitik og er den tilgængelig for kunder
- Har virksomheden en sikkerhedsstrategi og vil den vær tilgængelig for kunder
- Hvilke compliancekrav skal virksomheden efterleve
- Er der specielle sikkerhedsforhold som virksomheden ønsker at oplyse
- Har virksomheden nogle sikkerhedscertifikater
- Hvordan kontrollerer virksomheden deres underleverandører
- Hvordan håndterer virksomheden awareness
- Har virksomheden en sikkerheds governance struktur og er den tilgængelig for kunder
- Har virksomheden BCM-planer og testes disse
- Vil virksomheden dele risikoanalyser/billeder

Se spørgeskema under supplerende materiale.

Opgave 3

Opgave 1

Drøft 2 og 2 hvad der ville være relevante drøftelser med IT leverandører i relation til svar i opgave 2 . Vælg et af områderne fra opgave 1.

Hvordan kan Gurli tænke leverandørstyring ind i sin sikkerhedsplan?

Gå igennem leverandørdialogspørgeskemaet og nedfæld hvilke områder, det ville være relevante at drøfte og hvorfor - i relation til jeres køb.

15 minutter 2 og 2.

10 min opsamling omkring bordet efterfølgende.

Hvordan vælger man sin leverandør, eksempler?

- Leverandørens evne til at leve op til de stillede sikkerhedskrav.
- Leverandørens geografiske placering.
- Leverandørens accept af eventuelle overgangsforhold, hvis opgaven tidligere har været outsourcet eller varetaget af en anden leverandør.
- Leverandørens villighed til at samarbejde og til at lade sig efterse/revidere.
- Leverandørens accept af ophørsbestemmelser, herunder forpligtelsen til at opretholde cyber- og informationssikkerheden i hele ophørsperioden.
- Leverandørens økonomiske forhold og ejerforhold.
- Leverandørens brug af underleverandører, hvordan sikres at krav videreformidles?
- Leverandørens integritet og eventuelle konstaterede tilfælde af væsentlig misligholdelse af tidligere offentlige kontrakter.
- Størrelses- og afhængighedsforholdet mellem kunde og leverandør.
- Risikoen for leverandørlåsning pga. omkostningerne ved senere at skifte leverandør, når kunden først er blevet afhængig af leverandørens ydelser.

Mere specifikke leverance spørgsmål

- Hvordan sikkerhedstestes leverancer?
 - Patching ?
 - Incident management
 - Hvilket land ydes support fra?
 - Sikkerhedsgodkendelser / NDA
-
- Sikkerhedsspørgsmål til den specifikke leverance (naturligvis)!

Løbende styring af aftaler, eksempler:

- Statusmøder mellem kunde og leverandør (faste møder eller ad hoc).
- Skriftlig rapportering til kunden (fast afrapportering eller ved anmodning).
- Tilsyn hos leverandøren (enten varslet eller uanmeldt besøg).
- Intern audit/gennemgang eller egenkontrol foretaget af leverandøren.
- Ekstern audit/gennemgang foretaget af kunden eller en uvildig tredjepart.
- It-revision/audit via certificerede revisorer.
- Beredskabsøvelser med kunden som deltager eller observatør.
- PEN-tests

Leverandør adgang til virksomheds netværk.

- VPN adgang, der evt. begrænses og er on/off
- Screen sharring
- Fysisk tilstedeværelse

Kontroltiltag mod leverandør

Organisatoriske kontroller

Leverandørpolitik og klassificering

SLA'er og cyberkrav i kontrakter

Audits og compliance-rapporter

Tekniske kontroller

Zero trust (adgangsstyring)

MFA & segmentering for tredjepartsadgang

Continuous monitoring / Vulnerability disclosure program

Proceskontroller

Onboarding

Review/rapporterings-intervaller

Offboarding og adgangsophør

Backup og resiliens i leverandørkæden